Who wins?

When several controls apply at once, these rules decide the outcome. Learn the order, and you can predict the result before you test it.

SC-500 Academy posters
Front: identity, governance and data
Checked against Microsoft Learn on 20 October 2026

Conditional Access: how policies combine

1.1.2 1.1.3

Sign-in first factor done → **Every policy in scope applies** no priority order →
Any policy blocks? block wins → **All grant controls met** from every policy →
Access + session controls

- **Exclusions beat inclusions.** A user excluded by a policy is never in its scope, even if a group includes them.
- **Report-only** policies are evaluated and logged, never enforced.
- **Authentication strength** names the acceptable methods; plain "require MFA" accepts any second factor.
- Conditional Access only sees Microsoft Entra sign-ins. SQL logins, storage keys and SAS tokens never reach it.
- **Agents:** one acting on behalf of a user is evaluated as that user. One using its own agent identity or agent user account needs policies that target it: *All users* does not include agent user accounts.
- Proof: sign-in logs, *Conditional Access* tab - every policy that evaluated and its result.

PIM: eligible is not active

1.1.1

Eligible assignment grants nothing yet → **Activate** MFA, justification, approval →
Active for a set time → **Expires on its own**

- Activation rules (maximum duration, MFA, justification, approval) are **role settings**: every eligible user of that role gets them.
- Separate settings for Microsoft Entra roles, Azure resource roles and PIM for Groups.
- PIM limits *how long* privilege exists, not what the role can do while active.

App permissions and consent

1.1.4 1.1.5 1.1.6

Permission type	Acts as	Reach	Who can consent
Delegated	The signed-in user	Only what that user can reach	Users, if consent settings allow, for low-risk permissions
Application	The app itself, no user	Tenant-wide	An administrator only

- The **application object** lives in the home tenant; every tenant that consents gets its own **service principal**. Deleting the app registration deletes its home-tenant service principal; service principals in other tenants stay.
- Restricting user consent does not remove grants already given; review and remove them.
- A **managed identity** is a service principal whose credential Azure manages. System-assigned dies with its resource; user-assigned survives and can be shared.

Azure RBAC: permissions add up

1.3.5 1.3.6 1.3.7

Management group → **Subscription** → **Resource group** → **Resource** → **Effective = union of all**

- Assignments are **inherited downward and additive**. A narrower Reader removes nothing from a broader Owner.
- **NotActions and NotDataActions subtract only inside their own role.** Another role can still grant the action. They are not a deny.
- **Deny assignments** win over role assignments, but you cannot create them directly; Azure creates them (for example managed applications, deployment stacks). Customer-managed deny assignments are in private preview.
- **Actions** are the control plane, **DataActions** the data plane: Owner has no DataActions, so it reads no blobs or secrets directly, **but it can list storage account keys**.
- Azure roles and Microsoft Entra roles are separate systems.

Entra roles and Azure roles: two systems

1.3.5 1.3.6

	Microsoft Entra roles	Azure roles (RBAC)
Control	The directory: users, apps, policies	Azure resources: subscriptions down to a resource
Example	Global Administrator, Security Administrator	Owner, Contributor, Key Vault Secrets User
Scope	Tenant, administrative unit, or a single app	Management group, subscription, group, resource
Custom roles	Entra custom roles (P1 or P2)	Azure custom roles, with assignable scopes

- Holding Global Administrator does not grant Azure access. A Global Administrator can **elevate** to User Access Administrator at root scope, and every use should be temporary and audited.
- Least privilege on both: the smallest role at the narrowest scope, made eligible through PIM.

Resource locks

1.3.4

- Locks apply to **Azure Resource Manager (control-plane) operations only**, and are inherited by everything below the scope.
- The **most restrictive** lock in the chain wins.
- **CanNotDelete**: read and modify, no delete. **ReadOnly**: read only, including blocking POST operations such as listing storage account keys, which can break apps that "only read".
- Removing a lock needs `Microsoft.Authorization/locks/*`: Owner, User Access Administrator, and a few specialised built-in roles.

Azure Policy: what Deny does and does not touch

1.3.1 1.3.3

Create or update request → **Disabled** skipped → **Append / Modify** →
Deny → **Audit, Manual, AuditIfNotExists** → **DenyAction** →
Resource provider → **AuditIfNotExists / DeployIfNotExists** after success

- **Deny stops new create and update requests.** Resources that already exist are only reported non-compliant.
- Fix existing resources with **Modify or DeployIfNotExists plus a remediation task**; both need the assignment's managed identity.
- An assignment at a management group reaches every subscription below it, including future ones.
- **Exemption** (Waiver or Mitigated, optional expiry): stays in compliance results as Exempted. **Exclusion**: drops out of evaluation entirely.
- Owner plus a Deny policy still cannot create the forbidden resource. RBAC asks who; Policy asks what.

Backup protection: three layers

1.3.8

Soft delete deleted backups kept 14 days or more → **Immutable vault** no early deletion →
Multi-user authorization a Resource Guard approves risky changes

- Multi-user authorization only helps when **someone else controls the Resource Guard**, ideally in another subscription or tenant. Same owner: it stops mistakes, not a rogue administrator.
- Locking immutability and **always-on** soft delete are **irreversible**.

Key Vault: two gates and a safety net

1.2.2 1.2.3 1.2.4

Network vault firewall, private endpoint → **Authorization** Azure RBAC or access policies →
Data plane

- **The vault firewall guards the data plane only.** Management operations (tags, SKU, access policies) still go through Azure Resource Manager.
- **One permission model per vault.** Under access policies, anyone who can write the vault can grant themselves secret access; under Azure RBAC that needs role-assignment rights.
- **Soft delete** keeps deleted vaults and objects for 7 to 90 days. **Purge protection** blocks purging until retention ends and **cannot be turned off**.

Storage: both gates must pass

2.1.1 2.1.2 2.1.4

Network firewall, private endpoint → **Authorization** Entra ID, Shared Key, SAS → **Data**

- **Network rules subtract; they never grant.** An allowed subnet still needs a role, a key or a SAS.
- Disabling **Shared Key** stops account keys, account SAS and service SAS. Entra ID and **user delegation SAS** keep working.

To revoke	Do this
Service SAS bound to a stored access policy	Delete or change the policy
Any SAS signed with an account key	Rotate that key
User delegation SAS	Revoke user delegation keys

Three kinds of SAS

2.1.4

SAS	Signed with	Revoke by
Account SAS	Account key	Rotating that key
Service SAS	Account key	Deleting its stored access policy, or rotating the key
User delegation SAS	An Entra-issued user delegation key	Revoking user delegation keys

- Only a user delegation SAS can be traced to a person and is limited to that person's own permissions.
- A SAS expiration policy sets a maximum lifetime; violations are logged (default) or blocked.

Azure SQL

2.2.1 2.2.2

- **Firewall:** database-level IP rules are checked first, then server-level rules.
- **Microsoft Entra-only authentication** rejects SQL logins - the only way Conditional Access and MFA see every connection. Set the Entra admin first.
- **Auditing** at server and database level both run: each event is recorded twice.
- Dynamic Data Masking changes what a query returns, not what can be queried.

Ids such as 2.3.6 are positions in the official skills outline, assigned by the Academy. Microsoft does not number them.

CC BY 4.0. Not affiliated with Microsoft. Defaults, portals and licences change: confirm on Microsoft Learn.

Who wins?

The order a packet, a request or an alert is checked in decides what happens to it. Each chain reads left to right.

SC-500 Academy posters
Back: networks, applications, AI and monitoring
Checked against Microsoft Learn on 20 October 2026

NSGs: the path a packet walks

2.3.1 2.3.9

Inbound

Subnet NSG → Network interface NSG → **VM**

Outbound

VM → Network interface NSG → **Subnet NSG**

- Inside an NSG, rules run from the **lowest priority number** (100 to 4096); the first match ends evaluation.
- Default rules (65000 and up) allow traffic within the virtual network and deny inbound from the internet.
- NSGs are **stateful**: return traffic is allowed automatically.
- Proof: *Effective security rules* on the network interface, and IP flow verify.

Virtual Network Manager: admin rules first

2.3.2

Security admin rule → NSG rules → **Traffic**

Admin rule action	Result
Deny	Dropped. No NSG can allow it.
Always allow	Allowed. NSGs are not evaluated.
Allow	Passed on: NSGs still decide.

- A configuration does nothing until it is **deployed** to each target region.

Network Watcher: which tool answers what

2.3.9

Question	Tool
Is this flow allowed, and by which rule?	**IP flow verify**
Where does this packet go next?	**Next hop**
Which rules apply to this network interface, merged?	**Effective security rules**
Can A reach B end to end, and where does it fail?	**Connection troubleshoot**
What actually flowed?	**Virtual network flow logs** (NSG flow logs can no longer be created)

Azure Firewall: rule types beat priorities

2.3.8

Threat intel if on → **DNAT rules** → **Network rules** →
Application rules HTTP, HTTPS, MSSQL → **Infrastructure rules** → **Deny**

- **Network rules always run before application rules,** whatever the rule collection group priority. A network rule match ends processing.
- Within each rule type: rule collection groups by priority, then rule collections by priority. Parent policy groups come before child policy groups.
- Threat intelligence, when on, is processed **before every rule**: **Alert and deny** blocks known-malicious traffic; **Alert only** just logs it.

Routing and private endpoints

2.3.6 2.3.9

- Azure picks the route with the **longest matching prefix**. For the same prefix: user-defined route, then BGP, then system route.
- **Exception:** system routes for the virtual network, peerings and service endpoints win even over more specific BGP routes, and no route table overrides a service endpoint route.
- Traffic only reaches a firewall that a route sends it to. Proof: *Next hop* in Network Watcher.
- A private endpoint adds a private path; the **public endpoint stays open** until public network access is disabled.
- Clients must resolve the name to the private IP: the private DNS zone has to be linked or forwarded from every network that uses it.

Remote access paths

2.3.3 2.3.4 2.3.5 2.3.7

- **Point-to-site with Microsoft Entra ID** needs the **OpenVPN** tunnel type; only then do Conditional Access and MFA apply.
- **Virtual WAN routing intent**: a **private** routing policy sends branch and spoke traffic through the hub firewall; an **internet** routing policy sends internet traffic through it and straight out. **Forced tunnel** to on-premises is a private policy with 0.0.0.0/0 added as a prefix, and **no** internet policy.
- **Entra Private Access**: the Global Secure Access client sends traffic for published apps through Microsoft's edge to a private network connector. Conditional Access attaches to the app as an **enterprise application**.
- A **Private Link service** lets another tenant reach your load-balanced service through their own private endpoint, which you approve. Overlapping address spaces are fine.

Security Copilot: whose permissions?

4.3.2 4.3.3

Copilot role owner or contributor → **Plugin** enabled for the workspace →
User's own service roles → **Answer**

- Copilot roles open the door; **service roles decide what is in the room**. A contributor with no Sentinel role gets no Sentinel answers.

Web Application Firewall

3.3.8

Custom rules by priority → **Managed rules** anomaly score → **Mode**

- Each matched managed rule adds to an **anomaly score**; a score of **5 or more** (one critical match) blocks.
- **Detection mode logs and blocks nothing.** Only Prevention mode blocks.
- Changing the rule set version resets overrides and exclusions (Front Door; Application Gateway when done in the portal): **reapply them**.

API Management policies

3.3.9

Inbound → **Backend** → **Outbound**

- **on-error** runs instead when a step fails.
- Scopes nest: global, workspace, product, API, operation. Where <base /> sits decides whether the outer scope runs before or after.
- **The gateway only protects a backend that cannot be reached any other way.**

App Service and AKS

3.3.2 3.3.7

- **Access restrictions** run by priority; once any rule exists, unmatched traffic is denied by default (configurable).
- The **SCM (Kudu) site** has its own rule set unless it is set to use the main site's rules.
- With **Require authentication** set, App Service authentication turns away unauthenticated requests before the app's code runs. It proves who the caller is; what they may do is still the app's decision.
- **AKS:** with local accounts disabled, every user goes through Microsoft Entra ID. Azure Policy for AKS evaluates every request at admission; *audit* reports, *deny* rejects.

Defender for Cloud: where a plan is set

4.1.3

Management group policy DeployIfNotExists → **Subscription** plan on or off →
Resource override where supported

- Plans are switched on **per subscription** and stay on after the resources are deleted.
- Some plans can also be set per resource, overriding the subscription: **Defender for Servers Plan 1**, **Storage**, **App Service**, **AI services**.
- A policy at the management group turns plans on for subscriptions that do not exist yet.

AI: which control acts first

3.1.3 3.1.9

User input → **Tool call** agents → **Tool response** agents → **Output**

- **Foundry guardrails** act at these intervention points (agent guardrails and tool points: preview). An agent with its own guardrail **ignores the model's guardrail entirely**; with none, it inherits the model's.
- **Copilot Studio real-time protection** (preview) checks each planned tool call. If no decision returns in about one second, the default is to **allow**.
- **Defender for AI Services**, the Defender for Cloud plan, **alerts; it does not block.** Blocking is guardrails, the AI gateway, or Defender real-time protection rules for Foundry agents (preview).

Sentinel automation and retention

4.2.8 4.2.9

Incident or alert → **Automation rules** in order → **Playbook** Logic App

- Automation rules run in their **order number**; a rule can change the incident, suppress it until an expiry date, or run a playbook.
- Two permissions: Sentinel needs **Microsoft Sentinel Automation Contributor** on the playbook's resource group; the playbook needs its own identity's permissions.

Analytics tier rules and hunting → **Data lake** until total retention → **Deleted**

- Data past analytics retention is invisible to analytics rules. Reach it with a KQL job or a search job; restore does not work on data lake tier data.

Does it block, or only tell you?

1.3.1 4.1.1

Control	Blocks	Records or alerts
Conditional Access	Block grant	Report-only mode
Azure Policy	Deny; DenyAction (deletes)	Audit, AuditIfNotExists
SAS expiration policy	Block	Log (default)
WAF	Prevention mode	Detection mode
Foundry guardrail	Annotate and block	Annotate
Defender real-time protection for agents	Custom rule	Default rule (audit)
Defender for Cloud plans, including AI Services		Alerts
Sentinel analytics rules		Alerts and incidents
Sentinel automation, playbooks	Act after detection	

Read the verb in the question: *prevent* needs the left column, *detect* the right.

Ids such as 2.3.6 are positions in the official skills outline, assigned by the Academy. Microsoft does not number them.

CC BY 4.0. Not affiliated with Microsoft. Defaults, portals and licences change: confirm on Microsoft Learn.